

# Requesting a Freshness Nonce for Attestation Evidence in CSRs

What changed from draft-ietf-lamps-attestation-freshness -05 to -08

Hannes Tschofenig, Hendrik Brockhaus, Joe Mandel, Sean Turner

**IETF LAMPS Working Group, IETF 126, July 2026**

-05: 19 October 2025 → -08: 4 July 2026

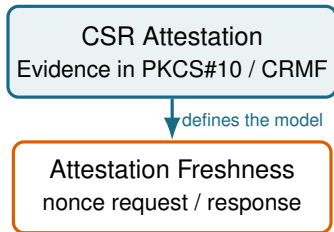
# Why the larger update now?

## A direct dependency

This document defines freshness for Evidence carried using  
`draft-ietf-lamps-csr-attestation`.

The CSR Attestation draft made **significant progress earlier this year**. That provided a firmer basis for:

- the architecture and terminology,
- the relation between a nonce and Evidence, and
- support for multiple Attesters and Evidence statements.



The -08 changes align the two drafts.

# Changes from -05 to -08

## -05

- “Conveying a nonce” separately in CMP, EST, and CMC
- Arrays / sequences of nonce requests
- type and free-form hint tied to a Verifier
- Protocol-specific structures evolved independently



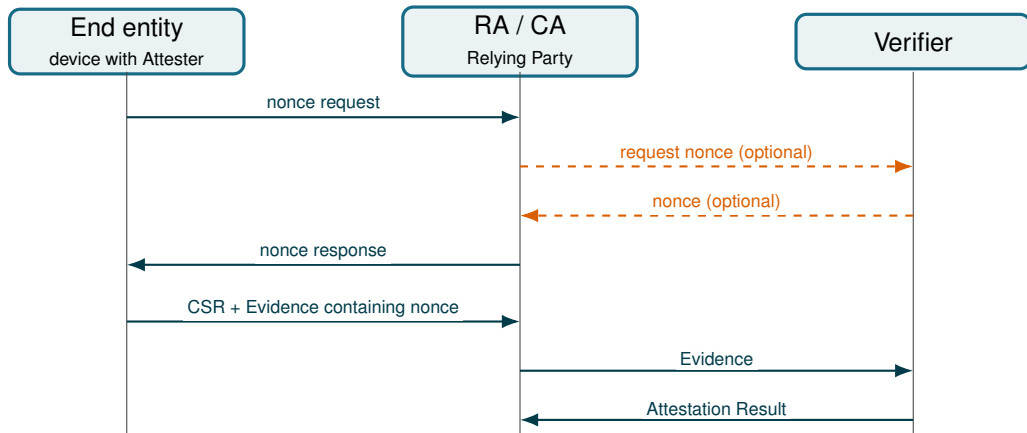
## -08

- One common architecture and message model
- One nonce request and one nonce response
- Typed, extensible reqInfo / respInfo
- Consistent ASN.1 and CDDL representations
- Protocol bindings are separate from message semantics

## Scope

Request a nonce before enrollment; include it only inside the attestation Evidence carried by the subsequent CSR.

# Architecture



**In scope:** the interface between the End Entity and the Relying Party (RA/CA). **Out of scope:** the interface between the Relying Party and the Verifier.

# Freshness: nonce vs. claim data

## Nonce-based freshness

- The RP or Verifier provides an unpredictable challenge; the Attester binds it to the Claims in protected Evidence.
- A match proves that the Evidence was produced after the challenge; the Attester needs no synchronized clock.
- An extra exchange and typically per-nonce state are required.

**In scope:** This document specifies the nonce exchange.

## Freshness data in Claims

- The Attester has no clock and therefore cannot add collection timestamps to the Claims.
- When the Claim values were collected is therefore unknown.
- Claim values may have changed between their collection and the production of the Evidence.
- Fresh Evidence does not by itself prove that individual Claim values were freshly collected.

**Out of scope:** This document neither defines nor evaluates freshness data in Claims.

**Nonce freshness of Evidence  $\neq$  freshness of individual Claim values.**

# Extensibility

## NonceRequest

**len** optional, 8–64 bytes

**reqTypeInfo** optional

- type: OID identifying the syntax
- reqInfo: type-specific input

ASN.1 for CMP / CMC

## NonceResponse

**nonce** required, 0 or 8–64 bytes

**expiry** optional, seconds

**respTypeInfo** optional

- type: OID identifying the syntax
- respInfo: type-specific output

CDDL for EST JSON / CBOR

reqInfo and respInfo are defined by external, OID-identified profiles.

# Protocol bindings are aligned

| Protocol          | Transport<br>nism            | mecha- | Encoding | Notable -08 detail                                                    |
|-------------------|------------------------------|--------|----------|-----------------------------------------------------------------------|
| CMP               | genm / genp                  |        | ASN.1    | New information types; HTTP getnonce and CoAP nonce paths             |
| EST over<br>HTTPS | GET or POST on /nonce        |        | JSON     | Dedicated application/est-attestation-freshness+json media type       |
| EST over<br>CoAPs | GET or POST on /nonce        |        | CBOR     | CoAP response codes and a dedicated CBOR media type / Content-Format  |
| CMC               | Controls in Full PKI Request |        | ASN.1    | Separate request / response control OIDs and explicit status handling |

**Same semantics across CMP, EST, and CMC; only the binding changes.**

# EST is no longer an open design point

## -05

- HTTPS + generic application/json
- JSON arrays and index-based correlation
- Absolute timestamp for expiry
- EST-over-CoAP / CBOR left as an open issue

## -08

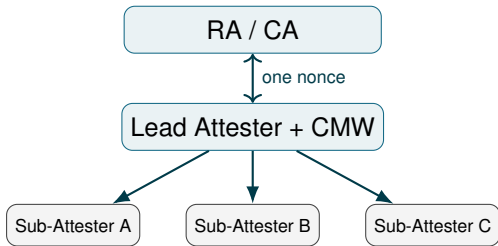
- HTTPS/JSON and secure CoAP/CBOR specified
- CDDL defines both representations
- One object; no positional correlation
- expiry consistently means validity in seconds
- Explicit success and error response codes
- Dedicated JSON and CBOR media types

## GET versus POST

GET when no optional request content is needed; POST when len or type-specific request information is conveyed.



# Multiple Attesters



Evidence-collection CMW combines the resulting Evidence statements

- -05 allowed arrays of requests and responses.
- -08 uses one nonce and one respInfo.
- A lead Attester distributes the nonce to sub-Attesters.
- CMW can carry multiple Evidence statements and, if needed, multiple type-specific information elements.

This follows the composite Attester model instead of inventing protocol-specific correlation.

# Operational and Security Requirements

## Nonce handling

- At least 64 bits of entropy
- Unique and never reused
- 8–64 byte wire representation
- No arbitrary truncation or padding
- Any transformation must be deterministic and profile-defined
- For Evidence conveyance in CSR, the nonce is inside the Evidence payload

## Deployment considerations

- Keep request, response, and CSR in the same PKI management context
- Bound outstanding state, lifetime, and request rate
- Treat type-specific information as potentially privacy-sensitive
- Clearly separate freshness of Evidence from semantics of other claims

# New registrations

## **CMP and CMC**

- CMP URI path segments
- CMP request / response information-type OIDs
- CMC request / response control OIDs
- ASN.1 module OID

## **EST**

- EST JSON and CBOR media types
- CoAP Content-Format
- Dedicated types replace generic `application/json`
- HTTPS/JSON and secure CoAP/CBOR are both covered

## **Result**

-08 specifies the registry surface needed to implement all three protocol bindings; the remaining numeric assignments are marked TBD.

# TPM 2.0 example

## 1. End entity advertises its capabilities

```
{
  "len": 32,
  "reqTypeInfo": {
    "type": "1.2.3.4.5",
    "reqInfo": {
      "certificate-name": ["aik-1", "aik-2"],
      "supported-hash-algo": ["TPM_ALG_SHA256"]
    }
  }
}
```

Two Attestation Keys are available; SHA-256 is supported.

The Attester creates a TPM quote using these selections and the nonce. The quote is carried later as Evidence in the CSR—not in `respInfo`. Informative example only; the OIDs are placeholders and no TPM profile is defined.

## 2. RA/CA selects challenge parameters

```
{
  "nonce": "<32-byte nonce, base64url>",
  "expiry": 600,
  "respTypeInfo": {
    "type": "1.2.3.4.6",
    "respInfo": {
      "tpm20-pcr-selection": [{
        "tpm20-hash-algo": "TPM_ALG_SHA256",
        "pcr-index": [0, 1, 2, 3]
      }],
      "certificate-name": "aik-1"
    }
  }
}
```

Use aik-1; quote PCRs 0–3 from the SHA-256 bank.

# Summary and next steps

- -08 is an architectural alignment with CSR Attestation
- one extensible nonce exchange
- consistent protocol bindings
- explicit support for composite-Attester use cases
- open-source implementation: [Guiliano99/RAT-E2E](#).

## One open issue

Establish an IANA registry for EST path segments; addressed by PR #38.